SOFTWARE ENGINEERING LAB 5: Static Code Analysis

Name: Sharanya C Bharadwaj

SRN: PES2UG24CS458

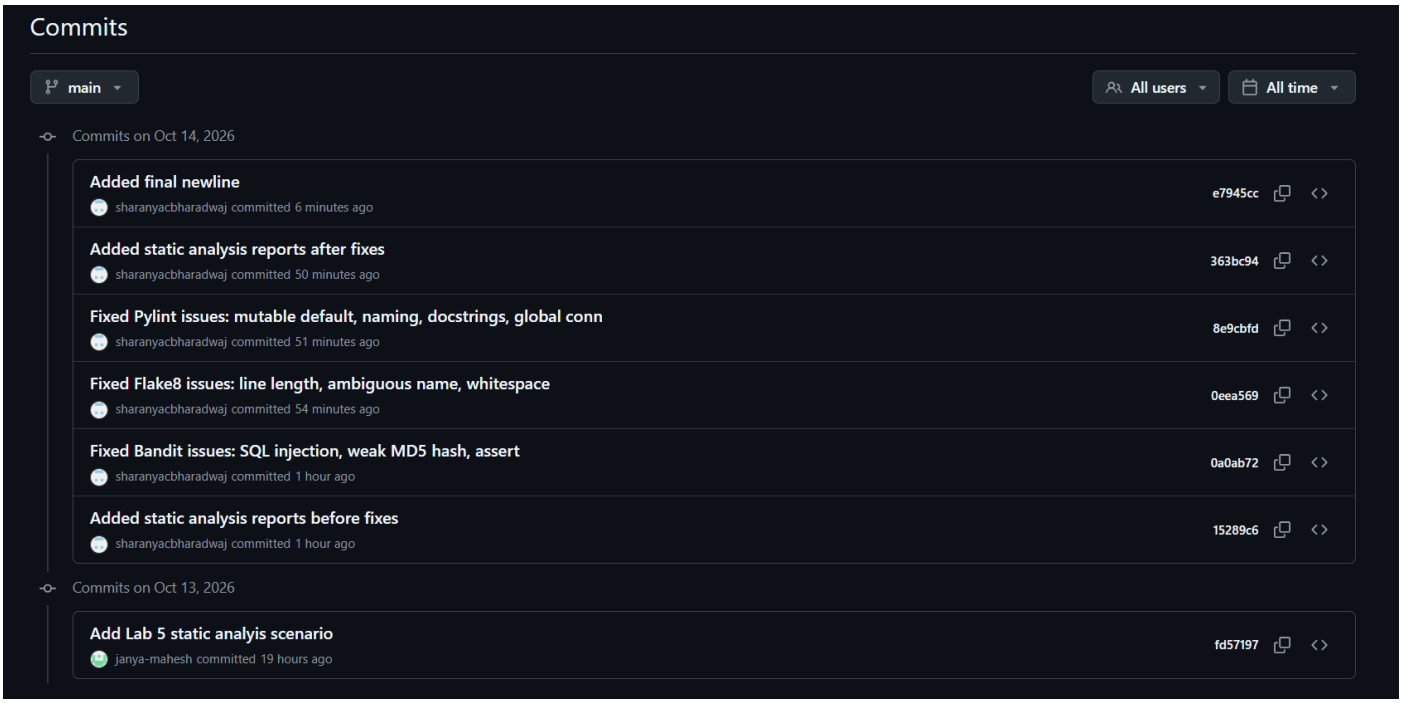
Section: 5H

Case Study Title: Wildlife Sightings

GitHub Repository(one with commits):
https://github.com/sharanyacbharadwaj/PES2UG24CS458_SE_Lab5_Static_Analysis

GitHub Repository(all lab submissions):
https://github.com/sharanyacbharadwaj/SE_LAB_PES2UG24CS458_SEC_H

Commits:



BEFORE FIXES

bandit_report_before.txt:

```
Run started:2026-10-14 06:41:19.034996+00:00

Test results:
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: .\wildlife_sightings.py:9:17
8       def logSighting(conn, species, zone, count, extras={}):
9           conn.execute("INSERT INTO sightings (species, zone, count) VALUES ('{}', '{}', {})".format(species, zone, count))
10          extras[species] = extras.get(species, 0) + count

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\wildlife_sightings.py:15:11
14      def observerId(observer):
15          return hashlib.md5(observer.encode()).hexdigest()[:6]
16

--------------------------------------------------
>> Issue: [B101:assert_used] Use of assert detected. The enclosed code will be removed when compiling to optimised byte code.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b101_assert_used.html
   Location: .\wildlife_sightings.py:36:4
35          logSighting(conn, "Hornbill", "East", 3, totals)
36          assert len(totals) == 3
37          print(observerId("Arun"), zoneSummary(conn, "North"), rarest(conn))

--------------------------------------------------
```

```
Code scanned:
        Total lines of code: 27
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 1
                Medium: 1
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 2
Files skipped (0):
```

Fig 1: Bandit report before fixes, showing 3 security issues (1 High, 1 Medium, 1 Low).

flake8_report_before.txt:

```
wildlife_sightings.py:5:80: E501 line too long (103 > 79 characters)
wildlife_sightings.py:9:80: E501 line too long (117 > 79 characters)
wildlife_sightings.py:19:80: E501 line too long (93 > 79 characters)
wildlife_sightings.py:27:80: E501 line too long (96 > 79 characters)
wildlife_sightings.py:28:5: E741 ambiguous variable name 'l'
wildlife_sightings.py:28:6: E225 missing whitespace around operator
```

Fig 2: Flake8 report before fixes, showing 6 style issues (long lines, ambiguous variable name, missing whitespace).

pylint_report_before.txt:

```
************* Module wildlife_sightings
wildlife_sightings.py:5:0: C0301: Line too long (103/100) (line-too-long)
wildlife_sightings.py:9:0: C0301: Line too long (117/100) (line-too-long)
wildlife_sightings.py:1:0: C0114: Missing module docstring (missing-module-docstring)
wildlife_sightings.py:8:0: C0116: Missing function or method docstring (missing-function-docstring)
wildlife_sightings.py:8:0: C0103: Function name "logSighting" doesn't conform to snake_case naming style (invalid-name)
wildlife_sightings.py:8:0: W0102: Dangerous default value {} as argument (dangerous-default-value)
wildlife_sightings.py:8:16: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
wildlife_sightings.py:9:17: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
wildlife_sightings.py:14:0: C0116: Missing function or method docstring (missing-function-docstring)
wildlife_sightings.py:14:0: C0103: Function name "observerId" doesn't conform to snake_case naming style (invalid-name)
wildlife_sightings.py:18:0: C0116: Missing function or method docstring (missing-function-docstring)
wildlife_sightings.py:18:0: C0103: Function name "zoneSummary" doesn't conform to snake_case naming style (invalid-name)
wildlife_sightings.py:18:16: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
wildlife_sightings.py:20:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
wildlife_sightings.py:26:0: C0116: Missing function or method docstring (missing-function-docstring)
wildlife_sightings.py:26:11: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
wildlife_sightings.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 3.46/10
```

Fig 3: Pylint report before fixes, scoring 3.46/10 with 17 issues.

AFTER FIXES

bandit_report.txt:

```
Run started:2026-10-14 07:00:49.695545+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 56
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

Fig 4: Bandit report after fixes, showing no security issues.

flake8_report.txt: No screenshots to post empty file

pylint_report.txt:

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

Fig5: Pylint report after fixes, scoring 10.00/10 with no issues.

Known Issues Table

Issue	Type	Line(s)	Description	Fix Approach
Weak MD5 hash (B324)	Security, High	15	MD5 is an old, unsafe hash	Used SHA-256 instead
SQL injection (B608)	Security, Medium	9	Values were added straight into the SQL text	Used ? placeholders for values
Assert used (B101)	Security, Low	36	assert is skipped when Python runs in optimised mode	Replaced with an if check that raises an error
Mutable default arg (W0102)	Bug	8	extras={} is shared across all calls	Set default to None and make a new dict inside
Global conn reused (W0621)	Bug	8, 18, 26	Function parameter had the same name as a global	Moved database setup into a function called from main()
Wrong naming style (C0103)	Style	8, 14, 18	Function names were camelCase	Renamed to snake_case
Missing docstrings (C0114, C0116)	Style	1, 8, 14, 18, 26, 32	Module and functions had no description	Added one line docstrings
Extra else after return (R1705)	Style	20	else was not needed	Removed the else
Line too long (E501, C0301)	Style	5, 9, 19, 27	Lines were longer than the limit	Split long lines
Unclear variable name (E741, E225)	Style	28	Variable l looks like 1, no spaces around =	Renamed to least and added spaces
No final newline (W292, C0304)	Style	Last line	File did not end with a line break	Added a line break at the end